AptoHire | Compliance & Security Readiness

Practical baseline for an early-stage platform • Version 1.0 • 30 October 2026

Status: This is a readiness checklist, not a certification, audit report, legal opinion or statement of compliance. No SOC 2 report or ISO 27001 certificate is claimed.

1. Priorities for AptoHire

Priority	Control area	Evidence to create
P0	Data inventory and privacy mapping	Data map; purposes; roles; retention; vendor list; sharing paths.
P0	Identity and access	MFA for privileged accounts; least privilege; access reviews; offboarding log.
P0	Database authorization	Document and test row-level security and server-side checks for every sensitive operation.
P0	Secrets and environments	Secret management; rotation; no secrets in client bundles/repos; separated dev/test/prod.
P0	Incident response	Named incident owner; severity definitions; contact tree; response log; tabletop exercise.
P1	Secure development	Code review; dependency scanning; patch cadence; test suite; release/rollback records.
P1	Backup and recovery	Backup schedule, access restrictions, restoration tests and recovery objectives.
P1	Vendor / AI review	Provider inventory, contracts, data processing terms, region, retention, subprocessors and AI input policy.
P1	Privacy rights operations	Consent records, withdrawal, correction/deletion request process, retention and grievance workflow.
P2	Independent assurance	Risk assessment, internal audit evidence, gap assessment, remediation tracking and external assessor selection.

2. ISO 27001 vs SOC 2

ISO/IEC 27001 is an information security management system standard. Certification, if pursued, requires a defined scope, risk treatment, documented controls and an independent certification audit. It is not achieved by having a checklist alone.

SOC 2 is an independent attestation report performed by a CPA firm against relevant Trust Services Criteria. Type I assesses design at a point in time; Type II examines operating effectiveness over a period. Do not call a startup 'SOC 2 certified' based only on policies or a readiness vendor.

Recommended sequence: implement P0 controls; document data flows and risk; operate controls consistently; conduct a gap assessment; select the assurance path based on actual enterprise buyer requirements and budget.

3. India privacy compliance planning

The Digital Personal Data Protection Act, 2023 and DPDP Rules, 2025 were notified with phased commencement. As of 30 October 2026, some provisions are already in force while major data-fiduciary duties are scheduled to commence 18 months after the 13 November 2025 notification (May 2027), subject to the official notifications and any subsequent amendments. Confirm the exact provision-by-provision timeline with counsel; build controls before commencement rather than waiting.

Minimum planning tasks: purpose-specific notices; consent and withdrawal records where applicable; data minimisation; accuracy; retention/deletion; reasonable security safeguards; grievance and rights workflows; breach handling; vendor/processor review; and a record of data categories and flows. Applicability and exceptions must be assessed for AptoHire's actual role and processing.

4. Evidence pack to maintain

• Information asset and data-flow inventory, including all five portals and shared backend boundaries.

• Access register, MFA coverage, privileged account review and offboarding records.

• Secure development lifecycle, threat model, dependency/SBOM records, code review and release evidence.

• Incident response plan, incident register, tabletop outcomes and remediation tracking.

• Vendor register and contracts for hosting, authentication, database, analytics, email, AI/model and payment providers.

• Privacy notices, consent logs, user-rights requests, retention schedule and deletion evidence.

• Backup and recovery records, restore test, availability monitoring and business continuity plan.

• Risk register, control owner matrix, internal audit / gap assessment and management review minutes.

5. Patent and IP compliance caution

India's Patents Act section 3(k) excludes a mathematical or business method, a computer programme per se and algorithms. A patent attorney should assess any claimed technical contribution under current Indian law and the applicable Computer Related Inventions Guidelines. Do not assume a matching algorithm or AI workflow is patentable.

6. Decision gates before enterprise sales

• Do not claim ISO certification, SOC 2 attestation, GDPR compliance or DPDP compliance unless the claim is accurate, scoped and supported by evidence.

• Do not promise a security control unless implemented, tested and owned.

• Complete a customer-specific security questionnaire using evidence, not aspirational statements.

• Set a security/privacy owner, remediation deadlines and a recurring review cadence.

• Engage a qualified privacy lawyer and independent security assessor when enterprise procurement justifies it.

Official reference points: MeitY DPDP Rules 2025 and commencement materials; IP India patent resources and CRI guidelines; ISO/IEC 27001 official standard materials; AICPA Trust Services Criteria / SOC 2 materials. Verify current versions and applicable dates before relying on this checklist.